KhangDaoz / **evodraw**

Code | Issues | **Pull requests** 1 | Agents | Actions | Projects | Wiki | Security and quality | Insi

View status | Code

# fix(server): implement security audit improvements #11

Open **lightzgls** wants to merge 2 commits into `main` from `fix/security-audit-improvements`

Conversation 7 | Commits 2 | Checks 0 | Files changed 7

**lightzgls** commented 17 minutes ago — Collaborator

This PR fixes the vulnerabilities identified in the pre-launch security audit:

- Fixes IDOR(Insecure Direct Object Reference) by verifying token roomId matches route parameter for file routes
- Mitigates insecure file uploads via strict magic byte checks (using `file-type` )
- Adds rate limiting for global API endpoints and room creation (using `express-rate-limit` )
- Applies `helmet` security headers
- Sets explicit payload limits for JSON parsing (5MB) and elements arrays (10,000 maximum)

Mention @copilot in a comment to make changes to this pull request.

**lightzgls** added 2 commits 23 minutes ago

`fix(server): implement security audit improvements` 3f84b1c

`refactor(server): extract rate limiters to middleware` 93aa722

**lightzgls** requested a review from **KhangDaoz** 17 minutes ago

**lightzgls** assigned **lightzgls** and **KhangDaoz** 17 minutes ago

**lightzgls** requested a review from **Copilot** 5 minutes ago

**Copilot** started reviewing on behalf of **lightzgls** 4 minutes ago — View session

**Copilot** AI reviewed 1 minute ago

View reviewed changes

**Copilot** AI left a comment

## Pull request overview

This PR implements a set of server-side hardening measures from a pre-launch security audit, focusing on access control for room file routes, safer file uploads, and HTTP-layer protections (rate limiting, headers, payload limits).

**Changes:**

- Added `helmet` security headers, global API rate limiting, and payload size limits for JSON/urlencoded bodies.

- Protected room file routes with token validation plus a roomId/route-param match to mitigate IDOR.
- Added file “magic-byte” validation via `file-type` and capped room update payload size via an elements array length limit.

## Reviewed changes

Copilot reviewed 6 out of 7 changed files in this pull request and generated 6 comments.

▶ Show a summary per file

Add Copilot custom instructions for smarter, more guided reviews. Learn how to get started.

Fix batch with Copilot

apps/server/src/controllers/file.controller.js

Comment on lines +31 to +36

```
31 +        const type = await fileTypeFromBuffer(file.buffer);
32 +        const allowedMimes = ['image/png', 'image/jpeg', 'image/gif', 'image/webp', 'application/pdf', 'image/svg+xml'
33 +
34 +        if (!type || !allowedMimes.includes(type.mime)) {
35 +            return res.status(400).json({ success: false, error: 'Invalid file type detected.' });
36 +        }
```

Copilot AI 1 minute ago

`file-type` does not detect text-based formats like SVG, so `fileTypeFromBuffer()` will return `null` for valid SVG uploads and they’ll always be rejected by this check (even though the multer fileFilter currently allows `image/svg+xml`). Either remove SVG from the allowed list, or implement a separate safe SVG validation path.

Fix with Copilot

Copilot uses AI. Check for mistakes.

Reply...

Resolve conversation

apps/server/src/controllers/file.controller.js

Comment on lines 45 to 48

```
37  45        await bucketFile.save(file.buffer, {
38  46            metadata: {
39     -              contentType: file.mimetype,
    47 +              contentType: type.mime,
40  48                metadata: {
```

Copilot AI 1 minute ago

The upload now uses detected type info ( `type.mime` / `type.ext` ) for Storage metadata and file extension, but later the MongoDB record still persists the client-provided `file.mimetype` (spoofable) rather than the verified `type.mime`. Update the persisted MIME type to match the verified value so stored metadata can’t be manipulated by the upload request.

Fix with Copilot

Copilot uses AI. Check for mistakes.

Reply...

Resolve conversation

apps/server/package.json

```
14  14      "dotenv": "^17.3.1",
15  15      "express": "^5.2.1",
    16  +   "express-rate-limit": "^8.4.1",
    17  +   "file-type": "^22.0.1",
```

Copilot AI 1 minute ago

`file-type@22` requires Node.js >= 22 (see the `engines` field in package-lock), but project docs indicate Node.js v18+ / v20 recommended. This will break installs/runtime on the documented Node versions unless the project's Node requirement is bumped and documented, or `file-type` is pinned to a version compatible with Node 18/20.

Suggested changeset **1**

apps/server/package.json

```
    ...     @@ -14,7 +14,7 @@
14  14          "dotenv": "^17.3.1",
15  15          "express": "^5.2.1",
16  16          "express-rate-limit": "^8.4.1",
17      -       "file-type": "^22.0.1",
    17  +       "file-type": "^20.0.0",
18  18          "firebase-admin": "^13.8.0",
19  19          "helmet": "^8.1.0",
20  20          "jsonwebtoken": "^9.0.3",
```

Commit suggestion | Add suggestion to batch

Copilot uses AI. Check for mistakes.

Reply...

Resolve conversation

apps/server/src/server.js

Comment on lines 60 to 62

```
55  60  // routes
56      - app.use('/api/rooms', roomRoutes);
    61  + app.use('/api/rooms', createRoomLimiter, roomRoutes);
57  62  app.use('/api/rooms/:roomId/files', fileRoutes);
```

Copilot AI 1 minute ago

`createRoomLimiter` is applied to all `/api/rooms` routes (create, join, update). The PR description says rate limiting is for room creation; as-is it will also throttle joining/updating rooms, which is a behavior change. Consider attaching `createRoomLimiter` only to the room creation POST route (e.g., in `room.routes.js`) or using a more targeted mount path.

Fix with Copilot

Copilot uses AI. Check for mistakes.

Reply...

Resolve conversation

apps/server/src/routes/file.routes.js

```
21  22
22  23  const router = Router({ mergeParams: true });
23  24
    25  + // Protect all file routes with token validation and IDOR check
```

Copilot AI 1 minute ago

This route now calls `validateToken`, but `validateToken` assumes the `Authorization` header exists and does `authHeader.split(' ')[1]`, which will throw when the header is missing/malformed and can result in a 500 instead of a clean 401. Either harden `validateToken` to handle missing/invalid headers, or add a small guard here before invoking it.

Suggested changeset **1**

apps/server/src/routes/file.routes.js

```
@@ -23,6 +23,20 @@
 23  23  const router = Router({ mergeParams: true });
 24  24
 25  25  // Protect all file routes with token validation and IDOR check
     26 + router.use((req, res, next) => {
     27 +     const authHeader = req.headers.authorization;
     28 +
     29 +     if (typeof authHeader !== 'string') {
     30 +         return res.status(401).json({ success: false, message: 'Unauthorized: Missing or invalid Authorization header.' });
     31 +     }
     32 +
     33 +     const parts = authHeader.split(' ');
     34 +     if (parts.length !== 2 || parts[0] !== 'Bearer' || !parts[1]) {
     35 +         return res.status(401).json({ success: false, message: 'Unauthorized: Missing or invalid Authorization header.' });
     36 +     }
     37 +
     38 +     next();
     39 + });
 26  40  router.use(validateToken);
 27  41  router.use((req, res, next) => {
 28  42      if (req.roomId !== req.params.roomId) {
```

Commit suggestion | Add suggestion to batch

Copilot uses AI. Check for mistakes.

Reply...

Resolve conversation

apps/server/src/routes/file.routes.js

Comment on lines +25 to +28

```
25 + // Protect all file routes with token validation and IDOR check
26 + router.use(validateToken);
27 + router.use((req, res, next) => {
28 +     if (req.roomId !== req.params.roomId) {
```

Copilot AI 1 minute ago

The IDOR check compares `req.roomId` and `req.params.roomId` with strict equality. Elsewhere in the codebase room codes are treated case-insensitively (normalized with `toUpperCase()`), so a lowercase `:roomId` URL would be rejected even with a valid token. Normalize both sides (e.g., trim + `toUpperCase()`) before comparing to avoid breaking clients.

Suggested changeset **1**

apps/server/src/routes/file.routes.js

```
@@ -22,10 +22,15 @@
 22  22
 23  23  const router = Router({ mergeParams: true });
 24  24
     25 + const normalizeRoomId = (roomId) => String(roomId ?? '').trim().toUpperCase();
     26 +
 25  27  // Protect all file routes with token validation and IDOR check
 26  28  router.use(validateToken);
 27  29  router.use((req, res, next) => {
 28     - if (req.roomId !== req.params.roomId) {
```

```
+       const tokenRoomId = normalizeRoomId(req.roomId);
+       const requestedRoomId = normalizeRoomId(req.params.roomId);
+
+       if (tokenRoomId !== requestedRoomId) {
            return res.status(403).json({ success: false, message: 'Forbidden: Access denied to this room.' });
        }
        next();
```

Commit suggestion | Add suggestion to batch

Copilot uses AI. Check for mistakes.

Reply...

Resolve conversation

**Review requested**

Review has been requested on this pull request. It is not required to merge. Learn more about requesting a pull request review.

1 pending review

**No conflicts with base branch**

Merging can be performed automatically.

Merge pull request

You can also merge this with the command line. View command line instructions.

Still in progress? Convert to draft

**Reviewers**

**Copilot**

**KhangDaoz**

Still in progress? Convert to draft

**Assignees**

**lightzgls**

**KhangDaoz**

**Labels**

None yet

**Projects**

None yet

**Milestone**

No milestone

**Development**

Successfully merging this pull request may close these issues.

None yet

**3 participants**